

Mapeo Detallado Pregunta ↔ Requisito Normativo (Versión GQM + PRAGMATIC)

Versión: 1.0

Nota: se reutilizan las preguntas de la encuesta integral, añadiendo columna de objetivo GQM.

1. Tabla de mapeo ampliada

Bloque	Pregunta	Objetivo GQM (G)	CMMC / Familia	NIST 800-171/172	ENS / NIS2 / DORA (genérico)
Gobernanza	1.1 Estrategia formal	G: Alinear ciberseguridad con la estrategia y riesgos corporativos	Governance / Risk Mgmt	RA-1, PM-1, PM-9	ENS (Org.1, Org.2), NIS2 Art. 21
Gobernanza	1.2 Reporte al órgano de gobierno	G: Asegurar supervisión periódica de riesgo ciber	Governance	PM-3, PM-8	ENS (Org.3), NIS2 (gobernanza)
Gobernanza	1.3 Rol CISO	G: Establecer responsabilidad clara de ciberseguridad	Governance / Personnel	PM-2, PS-1	ENS (Org.1, Org.4), NIS2 (responsables)
Gobernanza	1.4 Riesgo ciber en mapa de riesgos	G: Integrar el riesgo ciber en la gestión de riesgo global	Risk Management	RA-2, RA-3	ENS (Org.2, Op.1), NIS2 Art. 21
Gobernanza	1.5 Coordinación con cumplimiento	G: Coordinar ciberseguridad y cumplimiento normativo	Governance / Compliance	PM-1, CA-1	ENS (Org.5), NIS2 (supervisión)
Marcos	2.1 Marcos de referencia	G: Alinear controles con estándares reconocidos	Governance	PM-1	ENS (Org.1), NIS2 (alineación normas)
Marcos	2.2 Uso de CMMC	G: Utilizar CMMC/NIST como guía de madurez	Governance	PM-1	Buenas prácticas; refuerzo ENS/NIS2
Marcos	2.3 Nivel CMMC objetivo	G: Definir nivel de madurez objetivo	Governance / Planning	PM-3	ENS (Org.1), NIS2 (planificación)
Marcos	2.4 Mapeo ENS/NIS2/DO RA → CMMC/NIST	G: Asegurar coherencia entre marcos locales e internacionales	Governance / Risk	CA-2, PM-1	ENS (Org.1, Org.5), NIS2 (coordinación)

Activos	3.1 Inventario de activos	G: Conocer y gestionar el universo de activos relevantes	Asset Mgmt	CM-8	ENS (Op.5), NIS2 (medidas técnicas)
Activos	3.2 Parcheo de vulnerabilidades críticas	G: Reducir ventana de exposición a vulnerabilidades críticas	Config Mgmt	CM-6, SI-2	ENS (Op.8), NIS2 (vulnerabilidades)
Activos	3.3 Análisis de vulnerabilidades	G: Mantener visibilidad actualizada de debilidades técnicas	Risk / Vulnerability Mgmt	RA-5	ENS (Op.8, Op.12), NIS2 (pruebas)
Activos	3.4 Métricas de vulnerabilidades	G: Medir y gestionar la carga de vulnerabilidades	Risk Mgmt	RA-5, CA-7	ENS (Op.8), NIS2 (monitorización)
Accesos	4.1 Gestión de cuentas y privilegios	G: Asegurar principios de mínimos privilegios y control de cuentas	Access Control	AC-2, AC-6	ENS (Op.4), NIS2 (control de acceso)
Accesos	4.2 Uso de MFA	G: Reducir riesgo de compromisos por credenciales	Access / Ident. & Auth.	IA-2, IA-5	ENS (Op.2, Op.4), NIS2 (autenticación robusta)
Accesos	4.3 Accesos remotos	G: Proteger accesos remotos y teletrabajo	Access / Comm. Protection	AC-17, SC-7	ENS (Op.3, Op.4), NIS2 (seguridad de redes)
Datos	5.1 Clasificación de información sensible	G: Saber qué datos son críticos y dónde están	Access / Media Protection	MP-3, AC-3	ENS (Op.1, Op.7), RGPD art.32, NIS2
Datos	5.2 Cifrado en reposo	G: Proteger confidencialidad de datos sensibles en reposo	Media Protection	MP-5, SC-28	ENS (Op.7), NIS2 (medidas técnicas)

Datos	5.3 Cifrado en tránsito	G: Proteger datos sensibles en tránsito	Comm. Protection	SC-8, SC-13	ENS (Op.7, Pr.1), NIS2
Datos	5.4 DLP / exfiltración	G: Prevenir fuga de información sensible	Comm. Protection / SI	SC-7, SI-4	ENS (Op.7, Op.8), NIS2
Monitorización	6.1 Monitorización SIEM/SOC	G: Detectar actividad anómala de forma temprana	Audit / Incident Response	AU-6, IR-5	ENS (Op.8, Op.9), NIS2 (detección)
Monitorización	6.2 Métricas MTTD/MTTR	G: Reducir tiempos de detección y respuesta	Incident Response	IR-5, CA-7	ENS (Op.9), NIS2 (resiliencia)
Monitorización	6.3 Plan de respuesta	G: Contar con proceso estructurado ante incidentes	Incident Response	IR-1, IR-2	ENS (Op.9), NIS2
Monitorización	6.4 Simulacros	G: Validar y mejorar la capacidad de respuesta	IR / Contingency Planning	IR-3, CP-4	ENS (Op.9, Op.10), NIS2 (pruebas)
Formación	7.1 Formación general	G: Aumentar conocimiento básico en toda la plantilla	Awareness and Training	AT-2	ENS (Org.2), NIS2
Formación	7.2 Formación específica	G: Robustecer roles de alto riesgo	Awareness and Training	AT-3	ENS (Org.2), NIS2
Formación	7.3 Simulaciones de phishing	G: Medir y mejorar resistencia a ingeniería social	Awareness and Training	AT-2, AT-4	ENS (Org.2, Op.9), NIS2
Formación	7.4 Cultura de reporte	G: Fomentar reporte temprano de incidentes/sospechas	Awareness	AT-2	ENS (Org.2), NIS2
Proveedores	8.1 Proveedores críticos	G: Identificar actores clave en la cadena de suministro	Supply Chain Risk	SR-2	ENS (Org.3, Op.11), NIS2

Proveedores	8.2 Cláusulas de seguridad	G: Formalizar requisitos de seguridad a terceros	Supply Chain Risk	SR-3, SR-5	ENS (Org.3, Op.11), NIS2
Proveedores	8.3 Evaluación periódica	G: Evaluar y mejorar la postura de seguridad de proveedores	Supply Chain Risk	SR-6	ENS (Org.3, Op.11), NIS2
Documentación	9.1 SSP	G: Disponer de descripción estructurada de sistemas y controles	Planning / Documentation	PL-2, PL-8	ENS (Org.1, Org.5), NIS2
Documentación	9.2 POA&M	G: Gestionar planes de acción con seguimiento	Plan of Action	CA-5, PM-4	ENS (Org.5), NIS2
Documentación	9.3 Evidencias	G: Demostrar cumplimiento de controles con evidencias	Audit	AU-3, AU-6	ENS (Org.5, Op.9), NIS2
Métricas	10.1 KPIs/KRIs	G: Definir conjunto estable de indicadores	Governance / Risk	PM-1, CA-7	ENS (Org.2, Org.5), NIS2
Métricas	10.2 Frecuencia de reporte	G: Dar visibilidad periódica de la postura de seguridad	Governance	PM-3, CA-7	ENS (Org.3), NIS2
Métricas	10.3 Índices de madurez	G: Sintetizar madurez en indicadores compuestos	Governance / Risk	PM-4, CA-7	ENS (Org.2), NIS2
Inversión	11.1 Evolución de inversión	G: Alinear inversión con riesgo y madurez	Governance / Risk	PM-3, RA-3	ENS (Org.2), NIS2
Inversión	11.2 ROI	G: Evaluar retorno de iniciativas de ciberseguridad	Risk	RA-3	ENS (Org.2), NIS2
Inversión	11.3 Priorización	G: Priorizar mejoras según riesgo, coste y beneficio	Risk	RA-3, PM-4	ENS (Org.2), NIS2

Percepción	12.1 Autopercepción	G: Captar visión subjetiva de madurez	Governance	PM-1	—
Percepción	12.2 Ambición a 3 años	G: Conocer la ambición de mejora	Governance / Planning	PM-3	ENS (Org.1), NIS2
Percepción	12.3 Comentarios	G: Recoger matices cualitativos	—	—	—

Este mapeo conecta cada ítem de la encuesta con su objetivo GQM y con referencias normativas principales.